

BÁO CÁO NĂNG LỰC CÁ NHÂN VÀ THỰC HÀNH – ROLE C

Học phần: Kỹ thuật và Công nghệ dữ liệu lớn

Sinh viên: Nguyễn Hữu Thành Đạt
Namespace: bd-g05

Mã sinh viên: 24020062
Phạm vi kiểm tra: Task C – S3 Auth, Kubernetes RBAC, NetworkPolicy

1 Khung đối chiếu đánh giá (30 điểm)

Báo cáo tập trung trực tiếp vào 3 câu phần đánh giá độc lập (10 điểm/phần):

Hạng mục	Nội dung minh chứng trong báo cáo	Điểm
Đóng góp kỹ thuật cá nhân	Observer RBAC, kiểm chứng S3/Network, xác minh chéo Quota và đối chứng Before/After	10
Thực hành độc lập tại chỗ	Thực thi 2 lệnh trực tiếp: 1 lệnh cho phép (200 OK) và 1 lệnh từ chối (403 AccessDenied)	10
Giải trình & Chất vấn	Trả lời độc lập 3 câu hỏi đánh giá bản chất hệ thống (Exit Questions)	10

2 Đóng góp kỹ thuật cá nhân (10 điểm)

1. Phạm vi Role C thực hiện: Quản trị truy cập (*Access Governance*): cấu hình và kiểm chứng Kubernetes RBAC cho ServiceAccount observer, kiểm tra ma trận phân quyền S3, xác minh ranh giới NetworkPolicy và kiểm tra chéo quota rejection của Role A. Bộ test nghiệm thu đạt **22/22** kết quả (12/12 S3, 6/6 RBAC, 4/4 Network).

2. Thay đổi quy trách nhiệm trực tiếp: Observer RBAC. Xây dựng Role và RoleBinding cho ServiceAccount observer theo nguyên tắc đặc quyền tối thiểu: chỉ cấp quyền get/list/watch đối với pods, pods/log, events; tuyệt đối không có quyền đọc Secret hoặc can thiệp workload.

Trạng thái	Hành vi hệ thống	Bảng chứng kỹ thuật
Trước khi hoàn thiện	Chưa có phân quyền chặt chẽ; thiếu minh chứng principal observer bị giới hạn quan sát.	Cần cấu hình Role/RoleBinding và kiểm thử bằng ServiceAccount token.
Sau khi hoàn thiện	Độc được Pods/Events/Logs nhưng bị K8s API từ chối khi đọc Secret s3-config, tạo/xóa Pod.	K01–K03: Cho phép (Allow); K04–K06: Từ chối (Forbidden).

Artifact liên quan: manifests/task-c/observer-role*.yaml, evidence/task-c/results/K01.txt–K06.txt.

3. Kiểm chứng S3 Authorization sau hiệu chỉnh policy: Đồng bộ policy S3 về least privilege: ingestor chỉ thao tác trên research-raw; analyst chỉ thao tác trên research-release. Phát hiện và xử lý lỗi lệch credential (InvalidAccessKeyId) giữa client Secret và s3-config trên GKE; sau khi restart object store, bộ test S01–S12 đạt 12/12 kết quả kỳ vọng.

Test	Thao tác kiểm tra	Kỳ vọng chuẩn	Trước hiệu chỉnh	Kết quả cuối
S02	ingestor GET research-raw	Cho phép (Allow)	403 / Lỗi cấu hình credential	200 OK
S04	ingestor PUT research-release	Chặn (Deny)	200 OK (Ghi đè sai quyền)	403 AccessDenied
S10	analyst GET research-raw	Chặn (Deny)	200 OK (Độc trộm raw)	403 AccessDenied
S11	analyst LIST research-raw	Chặn (Deny)	200 OK (Liệt kê trái phép)	403 AccessDenied

Lưu ý phân biệt lỗi: Mã 403 AccessDenied chứng minh yêu cầu đã tới S3 endpoint và bị từ chối ở tầng authorization. Ngược lại, InvalidAccessKeyId, timeout hay EndpointConnectionError là lỗi định danh/kết nối mạng, không được dùng làm bằng chứng deny-policy.

4. Kiểm tra độc lập (Cross-check): Xác minh Quota Rejection của Role A: Role C thực hiện kiểm tra chéo nhằm chứng minh lỗi bị từ chối của Role A thực sự do **ResourceQuota** chứ không phải do RBAC, sai cú pháp manifest hay lỗi scheduling.

- Bước 1 (Ghi nhận Quota):** Chạy `kubectl -n "$NS" describe resourcequota team-budget` để ghi lại các trường Used/Hard (pods, requests.cpu, requests.memory).
- Bước 2 (Dry-run kiểm tra):** Thực thi lệnh dry-run phía server:
`| kubectl -n "$NS" create -f <task-a-disposable-pod.yaml> --dry-run=server -o yaml`
- Bước 3 (Đối chiếu nguyên nhân):** API server từ chối kèm thông báo `exceeded quota: team-budget` với resource cụ thể làm vượt ngưỡng (`used + requested > hard`). Điều này loại trừ nguyên nhân RBAC (vốn sẽ trả về Forbidden) hoặc scheduling (vốn sẽ nhận Pod nhưng để trạng thái Pending).

3 Kiểm tra thực hành độc lập tại chỗ (10 điểm)

Thực thi trực tiếp 2 lệnh dưới vai trò Pod analyst trên cluster trực tiếp và đối chiếu phản hồi:

Lệnh 1 – Allowed request: Đọc object từ bucket research-release.

```
| kubectl -n "$NS" exec analyst -- python /opt/s3lab.py probe get research-release fixture.txt
```

Kết quả: HTTP 200 OK, trả về nội dung fixture và "ok": true do policy cấp quyền Read:research-release.

Lệnh 2 – Forbidden request: Đọc trộm object từ bucket research-raw.

```
| kubectl -n "$NS" exec analyst -- python /opt/s3lab.py probe get research-raw fixture.txt
```

Kết quả: HTTP 403 AccessDenied do analyst hoàn toàn không có quyền trên bucket research-raw.

Giải trình: Cả hai yêu cầu đều phát sinh từ cùng một Pod/Identity analyst qua cùng endpoint S3. Kết quả phân hóa 200/403 chứng minh cơ chế phân quyền tầng ứng dụng S3 hoạt động độc lập và chính xác, không phải do ảnh hưởng của NetworkPolicy. Toàn bộ log raw xuất ra file: individual/practical-C-allowed.json và individual/practical-C-denied.json.

4 Giải trình và chất vấn (Exit Questions – 10 điểm)

Câu 1: Tại sao quyền K8s observer tách biệt với S3 reader, và namespace operator nằm ngoài biên cô lập?

- **Tách biệt mặt phẳng điều khiển:** ServiceAccount observer dùng token K8s để xác thực qua API server nhằm đọc tài nguyên cụm (Pods, Events, Logs) theo phân quyền RBAC. S3 reader dùng access key/secret key gọi vào endpoint lưu trữ đối tượng và được áp policy theo bucket/object. Quyền hạn ở hai hệ thống độc lập hoàn toàn. Minh chứng: K04–K06 xác nhận observer bị Forbidden khi truy xuất Secret hoặc thay đổi Pod.
- **Vị trí Namespace Operator:** Operator có quyền can thiệp vào RoleBinding, Secret và NetworkPolicy của namespace nên có thể chỉnh sửa hoặc bypass các rào chắn. Biên cô lập (*isolation boundary*) chỉ có giá trị ràng buộc các principal bị giới hạn (*constrained principals*), không áp dụng đối với người quản trị nắm quyền sửa chính sách.

Câu 2: Tại sao tải đồng thời 4 (concurrency 4) lại chậm hơn hoặc có latency cao hơn tải đơn (concurrency 1)?

Tải đồng thời làm xuất hiện hiện tượng tranh chấp tài nguyên vật lý trên môi trường single-node:

- Tranh chấp chu kỳ CPU, chi phí chuyển đổi ngữ cảnh (context switching) và lock luồng trong tiến trình lưu trữ S3.
- Bảo hòa băng thông I/O đĩa cứng (Disk I/O saturation) và chạm giới hạn hàng đợi I/O trên Persistent Disk.
- Hiện tượng tích lũy hàng đợi mạng (Queueing delay) làm tăng mạnh độ trễ đuôi (p95/p99) dù throughput tổng có thể không tăng.

Câu 3: Tại sao tự phục hồi Pod (Pod recovery) không tương đương với backup, HA, hay enforced retention?

Việc Pod chết và khởi tạo lại gắn đúng PersistentVolumeClaim (PVC) cũ chỉ chứng minh tính **bền vững khi crash (crash persistence)**:

- **Không phải Backup:** Không có bản sao lưu độc lập nào được tách rời sang vùng lưu trữ khác để khôi phục khi volume hỏng vật lý.
- **Không phải High Availability (HA):** Tồn tại khoảng thời gian chết (downtime) khi Pod đang khởi động lại; thiếu cơ chế nhân bản đa cụm / multi-replica phục vụ liên tục.
- **Không phải Enforced Retention:** PVC không bảo vệ dữ liệu khỏi thao tác xóa nhầm, ghi đè hoặc phá hoại nếu thiếu tính năng Versioning và khóa bất biến (Object Lock / WORM).

5 Danh mục bằng chứng kỹ thuật (Artifact Index)

Đường dẫn trong repository	Mục đích & Ý nghĩa kiểm thử
manifests/task-c/observer-role*.yaml	File khai báo Role và RoleBinding read-only cho ServiceAccount observer.
manifests/task-c/networkpolicy.yaml	Chính sách cô lập ingress cho object store (dùng cho N01–N04).
governance/policies-redacted.json	File phân quyền S3 bucket-scoped chính thức (đã ẩn credentials).
evidence/task-c/results/K01.txt-K06.txt	Raw output kiểm tra K8s RBAC (K04–K06 trả về mã Forbidden).
evidence/task-c/results/N01.json-N04.json	Raw output kiểm tra ranh giới mạng (N04 dùng namespace outsider fixture).
evidence/task-c/results/S_fix_1/S*.json	Lần test 1 ghi nhận lỗi ban đầu (dùng làm minh chứng Before behaviour).
evidence/task-c/results/S_fix_2/S*.json	Lần test 2 đạt 12/12 S3 nhưng mới cấu hình trên môi trường Local.
evidence/task-c/results/S_fix_3/S*.json	Bộ test chính xác, hoàn chỉnh đạt 12/12 sau khi đồng bộ lên Google Cloud (GKE).
individual/role-c-check-a-quota.txt	Bảng chứng kiểm tra độc lập server-side dry-run xác minh quota của Role A.
individual/practical-C-*.json	Raw output thực thi 2 lệnh thực hành trực tiếp tại buổi đánh giá.

6 Giới hạn và tính trung thực của bằng chứng

- Secret credentials và kubeconfig runtime được lưu trong thư mục `private/`, tuyệt đối không commit lên repository.
- Fixture outsider trong test N04 do nhóm tự cấu hình để giả lập truy cập từ namespace khác, không phải tài nguyên do đề bài cấp sẵn.
- Dữ liệu benchmark Task D và recovery Task E chỉ được Role C dùng để giải thích cơ chế câu hỏi Exit Questions; số liệu đo lường cụ thể thuộc trách nhiệm của thành viên đảm nhiệm task tương ứng.